

i-mSEC-AT Audit Summary

E-Rezept App iOS - v1.38.0

Audit Date: 10 Sep 2026

Auditor: Juan José López Jiménez

Classification: Confidential / Internal Use

Table of Contents

- [1. App information](#)
- [2. Actors](#)
- [3. Scope and limitations](#)
- [4. Evidence criteria](#)
- [5. Audit summary](#)
 - [5.1 Key takeaways \(Top findings\)](#)
 - [5.2 Representative positive controls observed](#)
 - [5.3 Risk scoring approach](#)
 - [5.4 Risk triage \(prioritized\)](#)
- [6. Main deficiencies](#)
- [7. Recommendations](#)
- [8. Visual Analytics](#)
- [9. Management Action Plan \(MAP\)](#)
- [Appendix A - Traceability index \(non-exhaustive\)](#)
- [Appendix B - Positive controls verification \(workbook traceability\)](#)

1. App information

Name	E-Rezept App iOS
Developer	gematik GmbH
Category	Digital Health / Electronic Prescription
Supported platforms	iOS 17.0 or later
Version	1.38.0
Last update	19/08/2026
Compatible idioms	iPhone
Source	Open source
License	EUPL-1.2
Main language	Swift

2. Actors

Auditor	Juan José López Jiménez
Requirement Engineering team	Juan José López Jiménez
Engineering Group (EN)	Juan José López Jiménez

3. Scope and limitations

This Audit Summary consolidates the compliance determinations recorded in the audit workbook. The results reflect the assessed application version and the evidence available to the pipeline. By default, the pipeline analyses source code and an unsigned IPA using static analysis, including MobSF static analysis. Dynamic iOS execution and effective production-signing properties are outside this default profile. Requirements containing an essential obligation that depends on either unavailable capability are therefore reported as not applicable rather than as security failures.

For applicable controls, absence of supporting evidence is handled conservatively as non-compliant. Such a result means that implementation was not demonstrated by the supplied artifacts; it is not, by itself, proof that the application lacks the control.

4. Evidence criteria

- Compliant: the workbook provides supporting evidence for every essential obligation that can be assessed in the supplied scope.
- Non-compliant (evidenced): one or more sufficiently covered observed signals contradict the control.
- Non-compliant (conservative): the control is applicable and assessable in the supplied profile, but the supplied artifacts do not contain sufficient supporting evidence.
- Not applicable: the functionality is absent, or an essential verification capability is outside the automated profile, including dynamic iOS execution, production-signing evidence, backend evidence, organizational documentation, or manual review.

5. Audit summary

The audit was carried out using the i-mSEC-AT (mobile SECurity Audit Tool).

Overall, 462 requirements were assessed. 79 were applicable controls and 383 were recorded as not applicable. Of the applicable controls, 34 had supporting evidence and 45 were classified as non-compliant: 23 from contradicting evidence and 22 from insufficient supporting evidence. The evidence-supported compliance rate is 43.04%. Conclusive positive or negative evidence was available for 72.15% of applicable controls, while 27.85% received a conservative determination. These metrics are not definitive measures of the application's complete security posture.

Out-of-scope counts may overlap for compound requirements. The not-applicable set includes 147 requirement(s) needing backend evidence, 136 needing organizational evidence, and 232 needing manual review.

Not-applicable scope breakdown: 36 requirement(s) depend on unavailable dynamic iOS analysis, 41 depend on production-signed IPA evidence, and 11 are not applicable for other functional, conditional, or profile-related reasons. Dynamic-analysis and signed-IPA counts may overlap when a compound requirement depends on both capabilities.

This report summarizes recurring control-gap patterns and proposes actionable remediations suitable for mHealth/EMR environments handling sensitive health information. Conservative determinations should be verified before being treated as confirmed defects.

5.1 Key takeaways (Top findings)

Key takeaways (Top findings)

- Hardcoded credentials / embedded secrets — High severity; 14 related non-compliant control(s) in the workbook.
- Embedded browser / WKWebView hardening gaps — High severity; 5 related non-compliant control(s) in the workbook.
- Transport security / certificate validation weaknesses — High severity; 5 related non-compliant control(s) in the workbook.
- Weak authentication lifecycle / brute-force protections — High severity; 5 related non-compliant control(s) in the workbook.
- Input validation & injection weaknesses (XSS/SQLi/command/log injection) — High severity; 4 related non-compliant control(s) in the workbook.
- Authorization / RBAC / least privilege gaps — High severity; 2 related non-compliant control(s) in the workbook.
- Supply chain governance & outdated components — High severity; 2 related non-compliant control(s) in the workbook.

5.2 Representative positive controls observed

The representative statements below are derived exclusively from controls recorded as Compliant in the audit workbook and include supporting signals (flags and/or evidence). Verification traceability is provided in Appendix B.

- Production builds must use the iOS default server-trust evaluation or a correctly implemented stricter trust policy and must never accept certificates solely because they are self-signed, issued by an untrusted authority, expired, or invalid for the requested host. Development trust exceptions must be isolated from production builds.
- Production builds must not contain custom TLS trust handling that accepts every certificate, disables hostname or trust evaluation, or otherwise bypasses the iOS trust model.
- The application must implement object serialization using safe serialization APIs to prevent security vulnerabilities such as unauthorized data access or deserialization attacks.
- The application must securely implement object deserialization by validating untrusted data before deserialization and protecting against unauthorized gadget chain execution.
- The application must validate the presence of enrolled biometric data, such as registered fingerprints or iris scans, before enabling API access for biometric authentication purposes.
- The application must implement secure biometric authentication methods, such as fingerprint or facial recognition, ensuring compatibility with biometric sensors and providing alternative authentication controls when biometric hardware is unavailable.
- The application must provide all users with the capability to manually terminate their communication session to ensure user-initiated logoff functionality.

5.3 Risk scoring approach

Severity and prevalence ratings in this report follow a qualitative prioritization rubric grounded in the audit workbook:

- Severity reflects potential impact on confidentiality, integrity, and availability of health information, including regulatory exposure.

- Workbook prevalence is the count of non-compliant requirements mapped to a weakness pattern. Requirements may share the same underlying evidence; these counts therefore do not represent distinct vulnerabilities or independent findings. The measure is a prioritization aid and must not be interpreted as exploit likelihood or probability.

Prevalence bands: High (≥ 50), Medium-High (20-49), Medium (10-19), Low-Medium (< 10).

5.4 Risk triage (prioritized)

Weakness pattern	Severity / prevalence	Workbook basis	Recommended owner	Target timeline
Hardcoded credentials / embedded secrets	High / Medium	14 mapped: 9 evidenced, 5 conservative.	Mobile Engineering / Security Engineering	0-90 days
Embedded browser / WKWebView hardening gaps	High / Low-Medium	5 mapped: 2 evidenced, 3 conservative.	Mobile Engineering	0-90 days
Transport security /	High / Low-Medium	5 mapped: 3 evidenced, 2	Mobile Engineering / DevOps	0-90 days

certificate validation weaknesses		conservative.		
Weak authentication lifecycle / brute-force protections	High / Low-Medium	5 mapped: 3 evidenced, 2 conservative.	Mobile Engineering	0-90 days
Input validation & injection weaknesses (XSS/SQLi/command/log injection)	High / Low-Medium	4 mapped: 2 evidenced, 2 conservative.	Mobile Engineering	0-90 days
Authorization / RBAC / least privilege gaps	High / Low-Medium	2 mapped: 0 evidenced, 2 conservative.	Mobile Engineering / Governance	0-90 days
Supply chain governance & outdated components	High / Low-Medium	2 mapped: 2 evidenced, 0 conservative.	DevOps / Security Engineering	0-90 days
Privacy notice / consent / governance gaps	Medium / Low-Medium	2 mapped: 1 evidenced, 1 conservative.	Governance / Product	0-180 days
Other control gaps	Low / Low-Medium	6 mapped: 1 evidenced, 5 conservative.	Engineering	0-365 days

6. Main deficiencies

The following deficiencies are synthesized as common weakness patterns based on non-compliant requirements. They include both evidenced contradictions and conservative determinations caused by insufficient evidence; the latter require verification before being treated as confirmed implementation defects.

Hardcoded credentials / embedded secrets (High)

Workbook basis: 14 related controls (9 evidenced contradiction(s), 5 conservative determination(s)).

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook contains either contradicting evidence or insufficient evidence for the related controls; consult the workbook justification for the determination basis of each control.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering / Security Engineering

Traceability (examples, non-exhaustive): SECM-CAT-ICU-001, SECM-CAT-ICU-002, SECM-CAT-ICU-003, SECM-CAT-ISU-001.

- Evidence anchor (from workbook description): The application must not embed credentials, private cryptographic keys, secret API keys, or other reusable authentication material in source code, configuration committed to version control, build logs, artifacts, or the...
- Evidence anchor (from workbook description): Applications shall not store passwords or secrets in the application binary, nor inhibit backend integration by using generic shared secrets.

Embedded browser / WKWebView hardening gaps (High)

Workbook basis: 5 related controls (2 evidenced contradiction(s), 3 conservative determination(s)).

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook contains either contradicting evidence or insufficient evidence for the related controls; consult the workbook justification for the determination basis of each control.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering

Traceability (examples, non-exhaustive): SECM-CAT-ISU-045, SECM-CAT-ISU-046, SECM-CAT-ISU-047, SECM-CAT-ISU-050.

- Evidence anchor (from workbook description): WKScriptMessageHandler interfaces must be exposed only to explicitly trusted WKWebView content, validate every message, avoid retaining handlers unnecessarily, and prevent access to sensitive native functionality.
- Evidence anchor (from workbook description): WKWebView must execute scripts only from explicitly approved local content or trusted origins. Native interfaces exposed through WKScriptMessageHandler or equivalent mechanisms must not be accessible to untrusted content...

Transport security / certificate validation weaknesses (High)

Workbook basis: 5 related controls (3 evidenced contradiction(s), 2 conservative determination(s)).

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook contains either contradicting evidence or insufficient evidence for the related controls; consult the workbook justification for the determination basis of each control.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering / DevOps

Traceability (examples, non-exhaustive): SECM-CAT-ICO-006, SECM-CAT-ICO-008, SECM-CAT-ICO-021, SECM-CAT-ICO-030.

- Evidence anchor (from workbook description): The application must assume that the network layer is unsecure and susceptible to eavesdropping. Implement end-to-end encryption and other secure communication practices to safeguard sensitive data transmitted over the n...
- Evidence anchor (from workbook description): The mobile application must ensure the confidentiality and integrity of electronically transmitted data, including electronic protected health information (ePHI), by implementing industry-standard encryption protocols (e...

Weak authentication lifecycle / brute-force protections (High)

Workbook basis: 5 related controls (3 evidenced contradiction(s), 2 conservative determination(s)).

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook contains either contradicting evidence or insufficient evidence for the related controls; consult the workbook justification for the determination basis of each control.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering

Traceability (examples, non-exhaustive): SECM-CAT-IAA-009, SECM-CAT-IAA-061, SECM-CAT-IPC-039, SECM-CAT-ICR-022.

- Evidence anchor (from workbook description): The application must encrypt passwords during transmission to ensure that no passwords are sent in clear text over the network.
- Evidence anchor (from workbook description): The application must implement asymmetric cryptography for authentication and authorization, ensuring private keys are securely generated and stored using platform-supported secure hardware, such as a Trusted Execution E...

Input validation & injection weaknesses (XSS/SQLi/command/log injection) (High)

Workbook basis: 4 related controls (2 evidenced contradiction(s), 2 conservative determination(s)).

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook contains either contradicting evidence or insufficient evidence for the related controls; consult the workbook justification for the determination basis of each control.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering

Traceability (examples, non-exhaustive): SECM-CAT-ISU-052, SECM-CAT-IOV-004, SECM-CAT-IOV-011, SECM-CAT-IBP-023.

- Evidence anchor (from workbook description): The application must validate all input data in WKWebView components used for network content, ensuring that insecure protocols are not trusted and all incoming data is sanitized.
- Evidence anchor (from workbook description): The application must prevent the population of WKWebView components loaded from the file URI scheme with user-supplied DOM input to avoid potential security vulnerabilities, such as injection attacks.

Authorization / RBAC / least privilege gaps (High)

Workbook basis: 2 related controls (0 evidenced contradiction(s), 2 conservative determination(s)).

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook contains either contradicting evidence or insufficient evidence for the related controls; consult the workbook justification for the determination basis of each control.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Mobile Engineering / Governance

Traceability (examples, non-exhaustive): SECM-CAT-IAA-085, SECM-CAT-IOS-011.

- Evidence anchor (from workbook description): The application must verify permissions before accessing services provided by external applications and handle denied requests gracefully.
- Evidence anchor (from workbook description): WKWebView components must restrict navigation, content origins, script-message handlers, file access, persistent website data, and JavaScript capabilities according to least privilege.

Supply chain governance & outdated components (High)

Workbook basis: 2 related controls (2 evidenced contradiction(s), 0 conservative determination(s)).

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook contains either contradicting evidence or insufficient evidence for the related controls; consult the workbook justification for the determination basis of each control.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: DevOps / Security Engineering

Traceability (examples, non-exhaustive): SECM-CAT-ISU-035, SECM-CAT-IBP-021.

- Evidence anchor (from workbook description): The application must be free of adware and known malware (via virus-checking against some established library of viruses), and should prevent the execution of malicious code, as well as disallow the uploading of malicious...
- Evidence anchor (from workbook description): The mobile health application must adhere to secure memory management best practices when using native code. This includes preventing vulnerabilities such as buffer overflows, use-after-free errors, and memory leaks thro...

Privacy notice / consent / governance gaps (Medium)

Workbook basis: 2 related controls (1 evidenced contradiction(s), 1 conservative determination(s)).

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook contains either contradicting evidence or insufficient evidence for the related controls; consult the workbook justification for the determination basis of each control.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Governance / Product

Traceability (examples, non-exhaustive): SECM-CAT-IOS-006, SECM-CAT-IOS-008.

- Evidence anchor (from workbook description): The application and included third-party SDKs must provide accurate privacy manifests and required-reason API declarations consistent with actual data collection and API use.
- Evidence anchor (from workbook description): Sensitive information must not remain visible in app-switcher snapshots, screenshots, screen recordings, notifications, widgets, or other system surfaces unless explicitly required.

Other control gaps (Low)

Workbook basis: 6 related controls (1 evidenced contradiction(s), 5 conservative determination(s)).

Expected: Controls in this area should provide robust, consistently enforced safeguards appropriate to health data processing.

Observed: The audit workbook contains either contradicting evidence or insufficient evidence for the related controls; consult the workbook justification for the determination basis of each control.

Impact: Deficiencies can increase the likelihood and impact of security incidents affecting confidentiality, integrity, or availability.

Recommended owner: Engineering

Traceability (examples, non-exhaustive): SECM-CAT-ISU-020, SECM-CAT-IOV-024, SECM-CAT-ICO-020, SECM-CAT-IPC-037.

- Evidence anchor (from workbook description): There should be means of providing feedback (e.g., provide a security email address (e.g., security@domain.com)).
- Evidence anchor (from workbook description): The application must disable clipboard functionalities, including cut, copy, and paste, for text fields containing sensitive data or restrict clipboard access to the application only.

7. Recommendations

Recommendations are organized by the same weakness patterns presented in the Main deficiencies section. Confirm conservative determinations through the required manual, backend, runtime or signed-artifact evidence before scheduling implementation work.

Hardcoded credentials / embedded secrets

- Remove confirmed embedded secrets, rotate exposed values, and retrieve credentials through an approved secrets service or authenticated backend exchange.
- Run secret scanning on commits and release artifacts, and block merges when a verified credential is detected.
- Verify that mobile clients receive only revocable, least-privilege credentials and never a shared backend secret.

Embedded browser / WKWebView hardening gaps

- Restrict WKWebView navigation to an explicit scheme and host allowlist, and cancel every navigation that does not match it.
- Disable JavaScript, file access, persistent website data, message handlers, and other browser features unless the use case requires them.
- Validate script-message payloads and test redirects, custom schemes, untrusted links, phishing layouts, and ATS behavior.

Transport security / certificate validation weaknesses

- Remove confirmed ATS exceptions and certificate-validation bypasses, then validate the effective release configuration.
- Use platform trust evaluation correctly and test rejection of expired, mismatched, untrusted, and intercepted certificates.
- Apply certificate or public-key pinning only when justified by the threat model and supported by a safe rotation strategy.

Weak authentication lifecycle / brute-force protections

- Verify server-enforced throttling, lockout, session expiry, revocation, and reauthentication for sensitive actions.
- Add integration tests for repeated failures, concurrent sessions, logout, account recovery, and expired credentials.
- Use phishing-resistant or step-up authentication only where the authentication risk assessment requires it.

Input validation & injection weaknesses (XSS/SQLi/command/log injection)

- Validate untrusted input at each trust boundary using allowlists, typed parsers, canonicalization, and context-appropriate output encoding.
- Use parameterized data access and structured logging; do not construct commands, queries, HTML, or log records through string concatenation.
- Add focused tests for URL schemes, Universal Links, WKWebView navigation, decoded payloads, and malformed server responses.

Authorization / RBAC / least privilege gaps

- Document the authorization matrix and enforce access decisions on the trusted backend rather than in the mobile UI alone.
- Add negative authorization tests for horizontal access, vertical privilege escalation, and cross-tenant identifiers.
- Review App Groups, Keychain Access Groups and external entry points for least-privilege access.

Supply chain governance & outdated components

- Pin and review dependencies, generate an SBOM, and define remediation targets for exploitable vulnerabilities.
- Enable automated dependency monitoring and verify package provenance, checksums, signatures, and approved registries where available.
- Remove unsupported components and document exceptions with an owner and expiration date.

Privacy notice / consent / governance gaps

- Map collected data and purposes to notices, consent or another lawful basis, retention, deletion, and user rights.
- Review the privacy manifest and third-party SDK declarations against actual API and data use.
- Test consent withdrawal, data export/deletion, notification redaction, and minimization of health information.

Other control gaps

- Review the mapped requirements and collect the specific source, runtime, backend, organizational, or signed-artifact evidence required by each control.
- Remediate confirmed contradictions using a secure configuration appropriate to this control area and add focused regression tests.
- Re-run the assessment and manually verify any controls that static analysis cannot determine conclusively.

8. Visual Analytics

Figures below summarize workbook-derived outcomes and distributions. All figures: source: audit workbook.

Overall compliance distribution (workbook-derived)

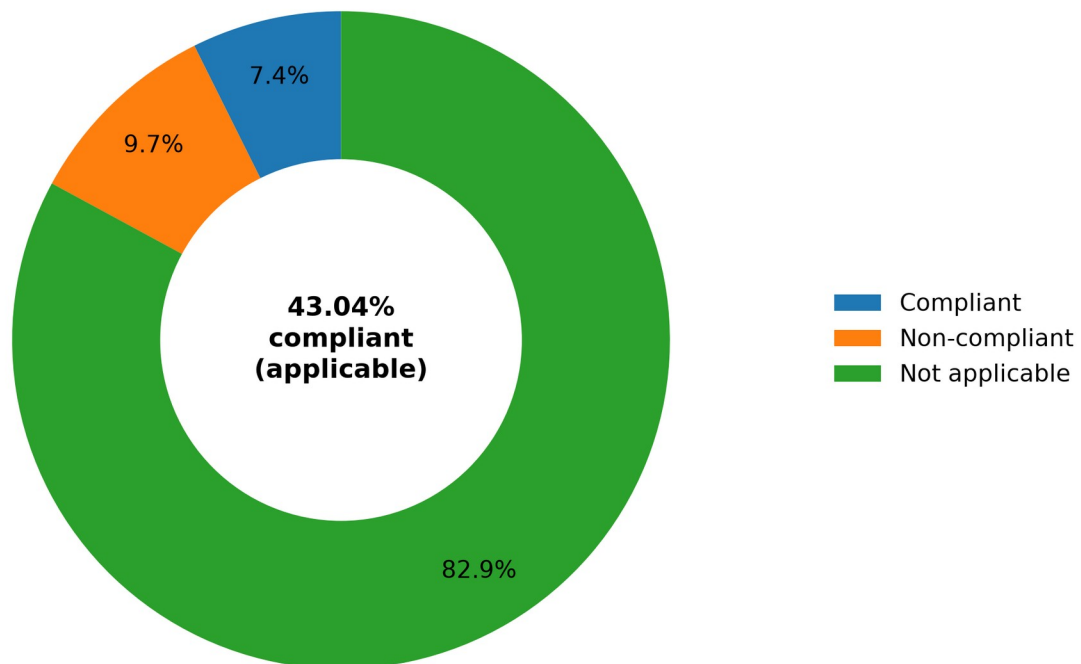
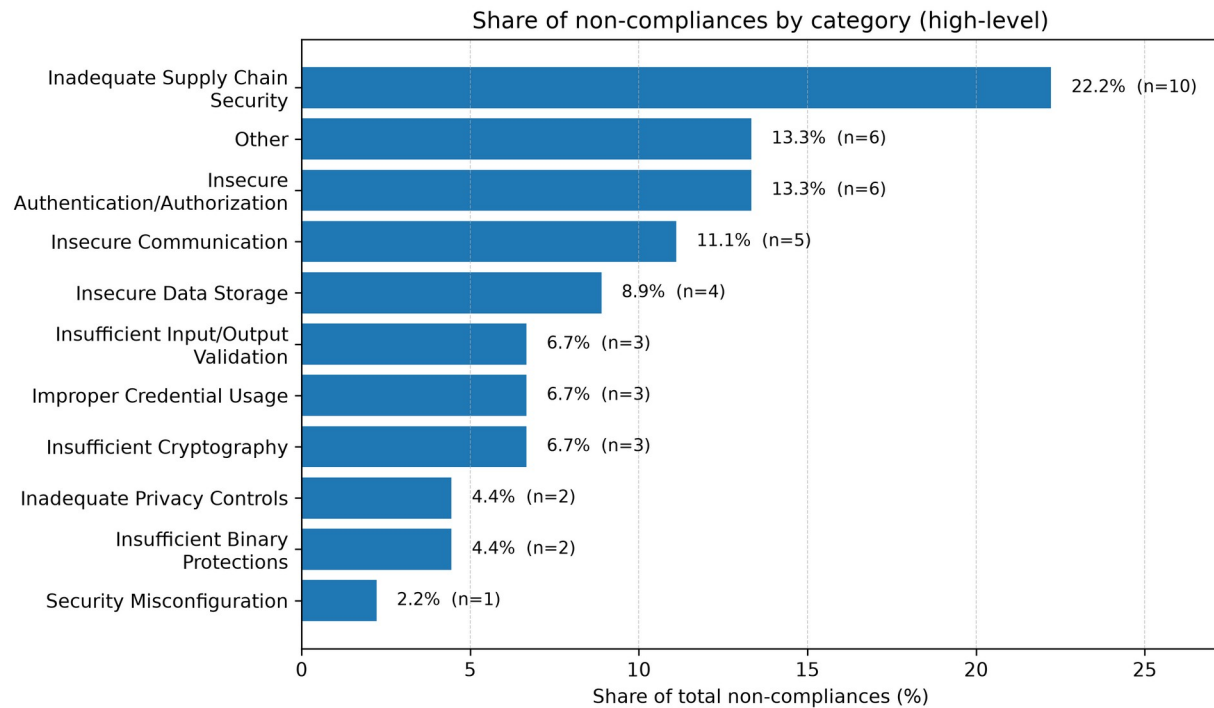
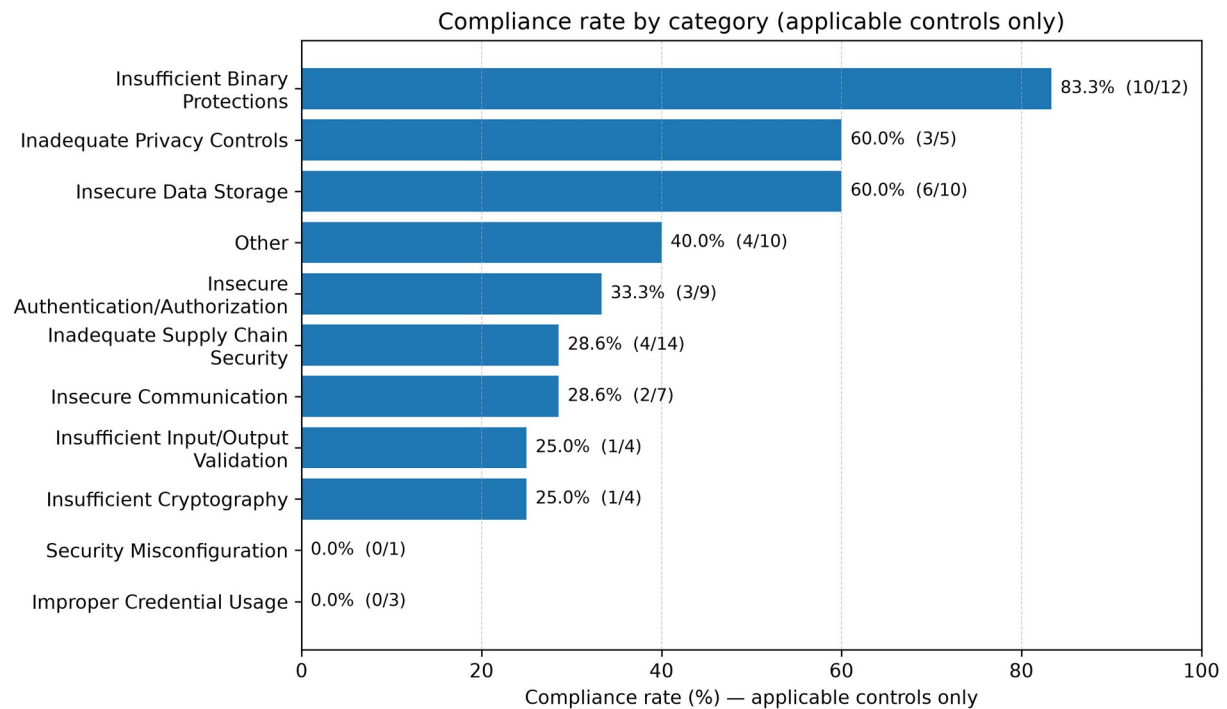


Figure 1. Overall compliance distribution (donut chart; source: audit workbook).



Source: audit workbook. Total non-compliances: 45.

Figure 2. Share of non-compliances by category (legible horizontal bars; source: audit workbook).



Note: (c/a) indicates Compliant / Applicable controls per category. Source: audit workbook.

Figure 3. Compliance rate by category (applicable controls only; source: audit workbook).

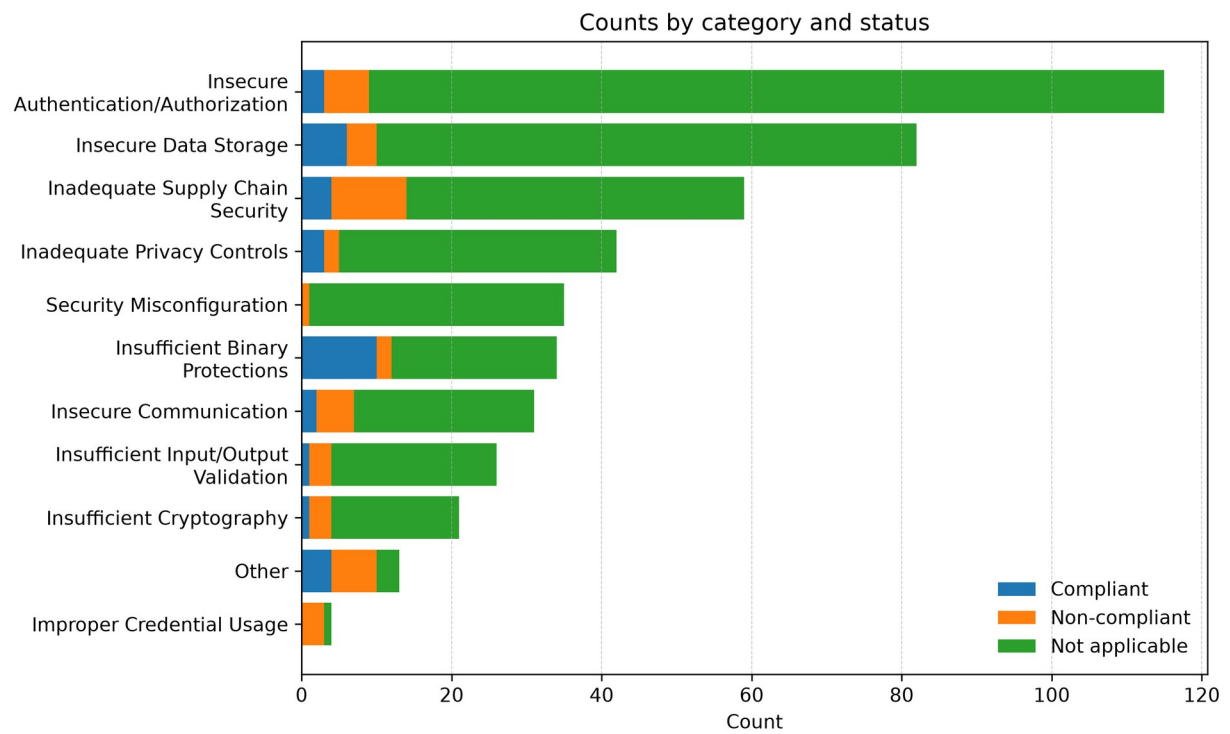


Figure 4. Counts by category and status (horizontal stacked bars; source: audit workbook).

9. Management Action Plan (MAP)

Severity and prevalence nomenclature follow the rubric in Section 5.3. Workbook prevalence is a prioritization count, not an estimate of exploit likelihood.

Finding / weakness pattern	Severity / prevalence	Workbook basis	Owner	Management action and acceptance	Target
Hardcoded credentials / embedded secrets	High / Medium	14 mapped: 9 evidenced, 5 conservative.	Mobile Engineering / Security Engineering	Remove confirmed embedded secrets, rotate exposed values, and retrieve credentials through an approved secrets service or authenticated backend exchange. Run secret scanning on commits and release artifacts, and block merges when a verified credential is detected. Verify that mobile clients receive only revocable, least-privilege credentials and never a shared backend secret. Acceptance: evidence is recorded and mapped controls can be re-tested.	0-90 days 09 Dec 2026
Embedded browser / WKWebView hardening gaps	High / Low-Medium	5 mapped: 2 evidenced, 3 conservative.	Mobile Engineering	Restrict WKWebView navigation to an explicit scheme and host allowlist,	0-90 days 09 Dec 2026

				and cancel every navigation that does not match it. Disable JavaScript, file access, persistent website data, message handlers, and other browser features unless the use case requires them. Validate script-message payloads and test redirects, custom schemes, untrusted links, phishing layouts, and ATS behavior. Acceptance: evidence is recorded and mapped controls can be re-tested.	
Transport security / certificate validation weaknesses	High / Low-Medium	5 mapped: 3 evidenced, 2 conservative.	Mobile Engineering / DevOps	Remove confirmed ATS exceptions and certificate-validation bypasses, then validate the effective release configuration. Use platform trust evaluation correctly and test rejection of expired, mismatched, untrusted, and intercepted	0-90 days 09 Dec 2026

				certificates. Apply certificate or public-key pinning only when justified by the threat model and supported by a safe rotation strategy. Acceptance: evidence is recorded and mapped controls can be re-tested.	
Weak authentication lifecycle / brute-force protections	High / Low-Medium	5 mapped: 3 evidenced, 2 conservative.	Mobile Engineering	Verify server-enforced throttling, lockout, session expiry, revocation, and reauthentication for sensitive actions. Add integration tests for repeated failures, concurrent sessions, logout, account recovery, and expired credentials. Use phishing-resistant or step-up authentication only where the authentication risk assessment requires it. Acceptance: evidence is recorded and mapped controls can be re-tested.	0-90 days 09 Dec 2026

Input validation & injection weaknesses (XSS/SQLi/command/log injection)	High / Low-Medium	4 mapped: 2 evidenced, 2 conservative.	Mobile Engineering	Validate untrusted input at each trust boundary using allowlists, typed parsers, canonicalization, and context-appropriate output encoding. Use parameterized data access and structured logging; do not construct commands, queries, HTML, or log records through string concatenation. Add focused tests for URL schemes, Universal Links, WKWebView navigation, decoded payloads, and malformed server responses. Acceptance: evidence is recorded and mapped controls can be re-tested.	0-90 days 09 Dec 2026
Authorization / RBAC / least privilege gaps	High / Low-Medium	2 mapped: 0 evidenced, 2 conservative.	Mobile Engineering / Governance	Document the authorization matrix and enforce access decisions on the trusted backend rather than in the mobile UI alone. Add negative authorization	0-90 days 09 Dec 2026

				tests for horizontal access, vertical privilege escalation, and cross-tenant identifiers. Review App Groups, Keychain Access Groups and external entry points for least-privilege access. Acceptance: evidence is recorded and mapped controls can be re-tested.	
Supply chain governance & outdated components	High / Low-Medium	2 mapped: 2 evidenced, 0 conservative.	DevOps / Security Engineering	Pin and review dependencies, generate an SBOM, and define remediation targets for exploitable vulnerabilities. Enable automated dependency monitoring and verify package provenance, checksums, signatures, and approved registries where available. Remove unsupported components and document exceptions with an owner and expiration date.	0-90 days 09 Dec 2026

				Acceptance: evidence is recorded and mapped controls can be re-tested.	
Privacy notice / consent / governance gaps	Medium / Low- Medium	2 mapped: 1 evidenced, 1 conservative.	Governance / Product	Map collected data and purposes to notices, consent or another lawful basis, retention, deletion, and user rights. Review the privacy manifest and third-party SDK declarations against actual API and data use. Test consent withdrawal, data export/deletion , notification redaction, and minimization of health information. Acceptance: evidence is recorded and mapped controls can be re-tested.	0-180 days 09 Mar 2027
Other control gaps	Low / Low- Medium	6 mapped: 1 evidenced, 5 conservative.	Engineering	Implement remediation actions aligned to the weakness pattern and validate effectiveness. Acceptance: evidence is recorded and	0-365 days 10 Sep 2027

				mapped controls can be re-tested.	
--	--	--	--	---	--

Appendix A - Traceability index (non-exhaustive)

For complete traceability and evidence, refer to the audit workbook.

- Hardcoded credentials / embedded secrets: SECM-CAT-ICU-001, SECM-CAT-ICU-002, SECM-CAT-ICU-003, SECM-CAT-ISU-001, SECM-CAT-ISU-058
- Embedded browser / WKWebView hardening gaps: SECM-CAT-ISU-045, SECM-CAT-ISU-046, SECM-CAT-ISU-047, SECM-CAT-ISU-050, SECM-CAT-ISU-051
- Transport security / certificate validation weaknesses: SECM-CAT-ICO-006, SECM-CAT-ICO-008, SECM-CAT-ICO-021, SECM-CAT-ICO-030, SECM-CAT-SMC-038
- Weak authentication lifecycle / brute-force protections: SECM-CAT-IAA-009, SECM-CAT-IAA-061, SECM-CAT-IPC-039, SECM-CAT-ICR-022, SECM-CAT-ICR-023
- Input validation & injection weaknesses (XSS/SQLi/command/log injection): SECM-CAT-ISU-052, SECM-CAT-IOV-004, SECM-CAT-IOV-011, SECM-CAT-IBP-023
- Authorization / RBAC / least privilege gaps: SECM-CAT-IAA-085, SECM-CAT-IOS-011
- Supply chain governance & outdated components: SECM-CAT-ISU-035, SECM-CAT-IBP-021
- Privacy notice / consent / governance gaps: SECM-CAT-IOS-006, SECM-CAT-IOS-008
- Other control gaps: SECM-CAT-ISU-020, SECM-CAT-IOV-024, SECM-CAT-ICO-020, SECM-CAT-IPC-037, SECM-CAT-IDS-072

Appendix B - Positive controls verification (workbook traceability)

This appendix verifies each representative positive-control statement shown in Section 5.2 by providing the originating PUID, flags used, and an evidence excerpt when available.

Positive control statement (as reported)	Workbook PUID	Flags used	Evidence / justification (excerpt)
Production builds must use the iOS default server-trust evaluation or a correctly implemented stricter trust policy and must never accept certificates solely because they are self-signed, issued by an untrusted authority, expired, or invalid for the requested host. Development trust exceptions must be isolated from production builds.	SECM-CAT-ISU-002	ios_certificate_pinning, ios_ats_arbitrary_loads	Result: yes for requirement SECM-CAT-ISU-002. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...
Production builds must not contain custom TLS trust handling that accepts every certificate, disables hostname or trust evaluation, or otherwise bypasses the iOS trust model.	SECM-CAT-ISU-005	ios_certificate_pinning, ios_ats_arbitrary_loads	Result: yes for requirement SECM-CAT-ISU-005. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...
The application must implement object serialization using safe serialization APIs to prevent security vulnerabilities such as unauthorized data access or deserialization attacks.	SECM-CAT-ISU-053	has_safe_object_serialization	Result: yes for requirement SECM-CAT-ISU-053. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...
The application must securely implement object deserialization by validating untrusted data before deserialization and protecting against unauthorized gadget chain execution.	SECM-CAT-ISU-054	has_safe_object_deserialization	Result: yes for requirement SECM-CAT-ISU-054. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...
The application must	SECM-CAT-IAA-093	has_biometric_enrollme	Result: yes for

validate the presence of enrolled biometric data, such as registered fingerprints or iris scans, before enabling API access for biometric authentication purposes.		nt_validation	requirement SECM-CAT-IAA-093. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...
The application must implement secure biometric authentication methods, such as fingerprint or facial recognition, ensuring compatibility with biometric sensors and providing alternative authentication controls when biometric hardware is unavailable.	SECM-CAT-IAA-094	has_secure_local_authentication	Result: yes for requirement SECM-CAT-IAA-094. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...
The application must provide all users with the capability to manually terminate their communication session to ensure user-initiated logoff functionality.	SECM-CAT-IAA-114	has_supports_manual_logout	Result: yes for requirement SECM-CAT-IAA-114. Based on the fingerprint and the flags mapped to this requirement, the application is compliant because the evaluated signals support ...